

NIST AI Risk Management Framework (AI RMF)

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 26: Compliance Frameworks and Standards

1. What the NIST AI RMF Is and Why It Matters

The National Institute of Standards and Technology (NIST) released the AI Risk Management Framework (AI RMF 1.0) in January 2023. Unlike most regulatory instruments, the AI RMF is voluntary, non-prescriptive, and technology-agnostic — it is designed to be applicable to any AI system across any industry sector. For CompTIA SecAI+ candidates, the AI RMF is a primary reference: it operationalises abstract AI governance principles into concrete organisational functions and outcomes that security professionals can implement and audit.

The AI RMF complements the NIST Cybersecurity Framework (CSF) and the NIST Privacy Framework. Security professionals who are already familiar with the CSF — which organises cyber risk management around IDENTIFY, PROTECT, DETECT, RESPOND, RECOVER — will find the AI RMF structurally similar but extended to address AI-specific risks such as bias, explainability failures, data drift, and adversarial manipulation. The AI RMF is accompanied by a freely available Playbook (ai.nist.gov) that provides practical guidance, suggested actions, and reference cases.

2. The AI RMF Core: Four Functions

The heart of the AI RMF is the Core, which organises AI risk management activity into four high-level functions. Each function is further decomposed into categories and subcategories — similar in structure to the NIST CSF Core.

Function	Acronym	Purpose	Security Team Role
GOVERN	GOV	Establish policies, accountability structures, risk culture, and oversight for AI risk management across the organisation	Define AI risk appetite; establish model owner roles; integrate AI risk into the enterprise risk register
MAP	MAP	Identify and categorise AI risks in context — understand who uses the system, for what purpose, and what could go wrong	Perform threat modelling; identify adversarial ML risks; assess data quality and bias risks
MEASURE	MEA	Analyse and assess AI risks using quantitative and qualitative methods; track metrics and evaluate controls	Run bias audits; conduct adversarial testing; benchmark model performance; track drift
MANAGE	MAN	Prioritise and treat identified AI risks; implement mitigations; respond to incidents; maintain residual risk awareness	Implement adversarial defences; conduct incident response; apply model patches; manage vendor risk

Exam mnemonic — GOVERN MAP MEASURE MANAGE: Remember the four functions as G-M-M-M. GOVERN sets the culture and policy; MAP identifies what risks exist; MEASURE evaluates how bad they are;

MANAGE treats them. This ordering reflects a plan-do-check-act logic.

3. GOVERN — Building an AI Risk Culture

GOVERN is the foundational function. Organisations cannot effectively MAP, MEASURE, or MANAGE AI risks unless leadership has established clear accountability, risk appetite, and governance structures. The AI RMF GOVERN function covers six categories:

- GOVERN 1 — Policies, processes, procedures, and practices: document how AI risk management will be conducted; assign responsibilities.
- GOVERN 2 — Accountability: ensure that specific roles are accountable for each AI system's risks throughout its lifecycle.
- GOVERN 3 — Organisational teams and resources: ensure that cross-functional teams (data science, legal, security, operations) are adequately resourced for AI risk work.
- GOVERN 4 — Organisational teams are committed to transparency and accountability: establish escalation paths and a culture where AI risks are reported without blame.
- GOVERN 5 — Organisational risk culture: AI risk appetite is defined and communicated; risk decisions are traceable to accountable individuals.
- GOVERN 6 — Policies and procedures address AI risks and are publicly available where appropriate: external transparency on AI risk posture where regulators or public trust requires it.

For security professionals, GOVERN is where they align AI risk management with existing enterprise risk governance. AI risk should not exist in a separate silo — it should be integrated into the enterprise risk register, the information security management system (ISMS), and the business continuity programme.

4. MAP — Understanding AI Risk in Context

MAP requires organisations to understand the context in which an AI system operates before attempting to assess or treat risks. Context includes the intended purpose, the user population, the deployment environment, the potential for misuse, and the societal impact of failure. MAP categories include:

- MAP 1 — Context is established: document who uses the system, for what purpose, in what environment, and under what constraints.
- MAP 2 — Scientific and technical assumptions underlying the AI system are understood and made transparent: document model architecture choices, training data assumptions, and known limitations.
- MAP 3 — AI risks are categorised as to likelihood and impact: assign risk ratings that reflect the specific deployment context, not generic model risk.
- MAP 4 — Risks from external deployment: assess risks introduced by third-party data, APIs, or AI components integrated into the system.
- MAP 5 — Likelihood and impact of AI risks are understood: synthesise MAP findings into a risk register entry for MEASURE and MANAGE.

Real-World Incident — Amazon AI Recruiting Tool (2018): Amazon developed an AI recruiting tool trained on historical hiring decisions, which were predominantly male. The MAP function was not applied: no one

contextualised that historical decisions encoded gender bias, that the deployment environment was high-stakes (employment decisions), or that the user population included job applicants who had no recourse. Amazon scrapped the tool in 2018 after discovering it systematically downgraded resumes containing the word 'women's.' A MAP analysis would have identified these risks before deployment.

5. MEASURE — Evaluating AI Risks with Metrics

MEASURE translates identified AI risks into measurable indicators that can be tracked, reported, and used to trigger remediation. For security professionals, MEASURE is where adversarial testing, fairness auditing, explainability assessment, and performance monitoring are formally embedded in the AI risk programme.

MEASURE Category	What to Measure	Example Metric
MEASURE 1 — Methods and metrics	Define how each risk identified in MAP will be quantified	Model accuracy degradation (%); bias metric (demographic parity difference); adversarial robustness score
MEASURE 2 — AI risks are evaluated	Apply the defined methods; generate measurements; document findings	Confusion matrix per demographic group; SHAP value distribution; attack success rate under FGSM
MEASURE 2.5 — Fairness and bias	Assess whether the AI system produces equitable outcomes across groups	Equal opportunity difference; predictive parity; disparate impact ratio
MEASURE 2.6 — Explainability	Assess whether decisions can be explained to affected parties	LIME fidelity score; average explanation depth; user comprehension test results
MEASURE 3 — Tracking and monitoring	Continuously monitor model performance and risk metrics in production	Drift detection alerts; data quality dashboard; anomaly detection on inference logs
MEASURE 4 — Residual risk	Document risks that cannot be fully mitigated and obtain acceptance from accountable roles	Residual risk register; formal risk acceptance sign-off by model owner

6. MANAGE — Treating AI Risks

MANAGE covers the treatment of identified AI risks: prioritising them, implementing controls, responding to incidents, and maintaining situational awareness of residual risk. MANAGE is where the security team's operational capabilities — incident response, patch management, vendor risk management — are applied to AI-specific threats.

- MANAGE 1 — Risks are prioritised: use a risk matrix combining likelihood (from MAP) and impact (from MEASURE) to sequence remediation effort.
- MANAGE 2 — Strategies to maximise AI benefits and minimise negative impacts: select controls proportionate to risk; document the risk treatment decision.

- **MANAGE 3** — AI risks are tracked: maintain a live risk register with control effectiveness ratings; review at defined intervals.
- **MANAGE 4** — Risk treatments include knowledge of previous AI incidents: use lessons from past AI failures — internal and public — to inform risk treatment choices.

MANAGE also covers the AI incident response process. When an AI system behaves unexpectedly — whether due to adversarial attack, data drift, or model failure — the MANAGE function requires that organisations have defined escalation paths, containment actions, recovery procedures, and post-incident review processes. Security professionals should integrate AI incidents into the existing SIEM/SOAR pipeline and ensure that AI-specific indicators of compromise (IOCs) — such as anomalous inference patterns, unexpected output distributions, or training data integrity failures — are captured in monitoring tooling.

7. AI RMF Profiles and Tiers

The AI RMF includes two additional components beyond the Core: Profiles and Tiers, which are analogous to the same concepts in the NIST CSF.

A Profile represents an organisation's current or target state of AI risk management. A Current Profile documents what AI risk management practices are in place today; a Target Profile documents where the organisation wants to be. The gap between them is the AI risk management improvement roadmap. Security professionals use profiles to communicate AI risk posture to senior leadership and to prioritise remediation work.

Tiers describe the maturity and rigour of an organisation's AI risk management practices. The AI RMF defines four tiers: Tier 1 (Partial) — AI risk management is informal and reactive; Tier 2 (Risk Informed) — risk management practices exist but are not consistently applied; Tier 3 (Repeatable) — practices are formalised, documented, and consistently applied; Tier 4 (Adaptive) — practices are continuously improved based on experience and threat intelligence. Most organisations targeted by AI regulation should aim for at least Tier 3.

Analogy — AI RMF Tiers and Security Maturity Models: AI RMF Tiers map closely to CMM maturity levels and to the NIST CSF Implementation Tiers. If you have used either before, you already understand the tier concept: each step up represents moving from informal to formal to measurable to adaptive.

8. AI RMF and Adversarial Machine Learning

The AI RMF explicitly addresses adversarial ML as a subcategory of AI risk. In the MAP function, organisations must identify adversarial threat actors and their likely attack vectors. In MEASURE, they must quantify the model's robustness under adversarial conditions — typically via red-team exercises and standardised attack benchmarks. In MANAGE, they must implement defences such as adversarial training, input preprocessing, output monitoring, and model version control.

The AI RMF Playbook references NIST SP 800-series publications on adversarial ML, particularly NIST SP 1270 (Towards a Standard for Identifying and Managing Bias in AI) and the planned adversarial ML

taxonomy publication. Security professionals should track these publications as they define the technical vocabulary and control expectations that regulators will eventually codify into compliance requirements.

9. Mapping AI RMF to Other Standards

AI RMF Element	OECD AI Principle	EU AI Act Article	ISO/IEC 42001
GOVERN 2 (Accountability)	Accountability (Principle 5)	Art. 14 (Human oversight)	Clause 5.3 (Roles and responsibilities)
MAP 3 (Risk categorisation)	Robustness, security, safety (Principle 3)	Art. 9 (Risk management)	Clause 6.1 (Risks and opportunities)
MEASURE 2.5 (Fairness)	Human-centred values (Principle 2)	Art. 10 (Data governance)	Clause 8.4 (AI system impact assessment)
MEASURE 2.6 (Explainability)	Transparency (Principle 3)	Art. 13 (Transparency)	Clause 8.5 (AI system documentation)
MANAGE 4 (Incident lessons)	Accountability (Principle 5)	Art. 62 (Reporting of serious incidents)	Clause 10.2 (Nonconformity and corrective action)

10. Common Exam Traps

- Trap 1 — The AI RMF is mandatory for US federal agencies: FALSE. The AI RMF is voluntary. The Executive Order on AI (October 2023) requires federal agencies to adopt AI risk management practices, but the AI RMF itself is advisory guidance, not a legal mandate.
- Trap 2 — GOVERN is the last step: FALSE. GOVERN is the first and foundational function. Without governance, MAP, MEASURE, and MANAGE cannot be sustainably implemented.
- Trap 3 — Tiers represent compliance levels: FALSE. AI RMF Tiers describe maturity, not compliance. An organisation at Tier 2 is not non-compliant — it is at an earlier stage of maturity.
- Trap 4 — The AI RMF replaces the NIST CSF for AI systems: FALSE. The AI RMF supplements the CSF; they are designed to be used together. AI cybersecurity risks remain in scope of the CSF.
- Trap 5 — MEASURE only applies to model accuracy: FALSE. MEASURE covers fairness, explainability, robustness, privacy, and reliability — not just predictive performance.

Key Terms Glossary

Term	Definition
NIST AI RMF	NIST AI Risk Management Framework (AI RMF 1.0, January 2023) — a voluntary, technology-agnostic framework for managing AI risks across four functions: GOVERN, MAP, MEASURE, MANAGE.
GOVERN function	The AI RMF function that establishes organisational policies, accountability, risk culture, and oversight structures for AI risk management.
MAP function	The AI RMF function that identifies and contextualises AI risks — understanding who uses the system, for what purpose, and what could go wrong.

MEASURE function	The AI RMF function that quantifies identified AI risks using defined metrics, audits, and assessments.
MANAGE function	The AI RMF function that treats prioritised AI risks — implementing controls, responding to incidents, and tracking residual risk.
AI RMF Profile	A documentation of an organisation's current or target AI risk management state; used to identify gaps and priorities.
AI RMF Tier	A maturity descriptor for AI risk management: Tier 1 (Partial), Tier 2 (Risk Informed), Tier 3 (Repeatable), Tier 4 (Adaptive).
AI RMF Playbook	The companion resource to the AI RMF (at ai.nist.gov) providing suggested actions, subcategory guidance, and reference cases.
Data drift	The degradation of model performance over time as real-world data distributions diverge from the training data distribution — a MEASURE and MANAGE concern.

Quick Revision Checklist

- Name the four AI RMF Core functions in order and recall the purpose of each.
- Explain why GOVERN is the foundational function that must come before MAP, MEASURE, and MANAGE.
- Describe what a Current Profile and Target Profile are, and how the gap between them drives AI risk improvement.
- State the four AI RMF Tiers and distinguish between maturity (what tiers measure) and compliance (what regulations enforce).
- Map MEASURE 2.5 to the OECD fairness principle and the EU AI Act data governance article.
- Explain the Amazon AI recruiting case and identify which AI RMF function failure it illustrates (MAP).
- Know that the AI RMF is voluntary but aligned with federal AI Executive Order expectations.
- List three types of AI risk that MEASURE should quantify beyond model accuracy: fairness, explainability, and adversarial robustness.

10 Exam-Based MCQs — NIST AI RMF

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. Scenario: Elena is the CISO at a regional insurance company. The company has deployed six AI systems across claims processing, fraud detection, and customer segmentation — but there are no defined model owners, no AI risk policy, and no cross-functional AI risk committee. A regulator audit has flagged the absence of accountability structures as a critical finding. Which AI RMF function should the security team prioritise FIRST to address this situation?

- A) MAP — to identify and categorise the specific AI risks in each deployed model.
- B) MEASURE — to quantify the bias and performance risks already known to exist.
- C) GOVERN — to establish accountability structures, risk ownership, and policies before assessment begins.

D) MANAGE — to immediately implement adversarial defences across all systems.

Answer: C **Explanation:** C is correct because the AI RMF is explicit that GOVERN is foundational — without accountability structures and risk ownership, MAP and MEASURE assessments have no one responsible for acting on their findings. A is the correct second step after governance is established. B requires a measurement programme to have been defined, which is a GOVERN output. D is premature without knowing what specific risks to treat.

Q2. Scenario: A newly hired AI risk analyst at a bank is asked to begin assessing a customer credit-scoring model that has been live for two years. She asks which AI RMF function she should apply first to understand who uses the model, what decisions it supports, and what failure modes have been observed historically. Which AI RMF function MOST directly addresses the need to understand the context in which the model operates before any risk assessment is performed?

- A) GOVERN
- B) MAP
- C) MEASURE
- D) MANAGE

Answer: B **Explanation:** B is correct. The MAP function requires establishing context — the intended purpose, user population, deployment environment, and potential for misuse — before risks can be accurately identified or measured. GOVERN establishes policy, not contextual understanding. MEASURE quantifies risks after they have been identified. MANAGE treats risks after they have been assessed.

Q3. Scenario: James is a security architect at a healthcare network. An AI-powered diagnostic support tool has started producing systematically incorrect outputs for patients over 75, potentially due to data drift. The CISO has asked James to implement the controls that align with the AI RMF MANAGE function to address this situation and prevent recurrence. What should the security team implement to operationalise the MANAGE function for this AI system?

- A) A fairness audit using demographic parity metrics.
- B) An AI incident response plan with defined escalation, containment, and post-incident review procedures.
- C) A model Card documenting the training data and known limitations.
- D) A cross-functional AI risk committee with quarterly review meetings.

Answer: B **Explanation:** B is correct. The MANAGE function covers AI risk treatment, including incident response — when an AI system behaves unexpectedly, MANAGE requires defined escalation paths, containment actions, and post-incident reviews. A is a MEASURE 2.5 (fairness) activity. C is a MAP/GOVERN documentation activity. D is a GOVERN activity — establishing the committee is governance, not incident management.

Q4. An organisation's AI risk management practices are formally documented and consistently applied across all AI deployments, but are not yet reviewed or updated based on emerging threat intelligence. Which AI RMF Tier BEST describes this organisation?

- A) Tier 1 (Partial)
- B) Tier 2 (Risk Informed)
- C) Tier 3 (Repeatable)
- D) Tier 4 (Adaptive)

Answer: C **Explanation:** C is correct. Tier 3 (Repeatable) describes organisations with formalised, documented, and consistently applied AI risk management practices — but without the continuous improvement and threat-intelligence integration that characterises Tier 4 (Adaptive). Tier 1 is informal and reactive. Tier 2 exists but is inconsistently applied. Tier 4 requires active adaptation to new information.

Q5. Which AI RMF function failure does the Amazon AI recruiting tool case (2018) MOST directly illustrate?

- A) GOVERN — no AI risk policy existed.
- B) MAP — context, bias risk, and high-stakes deployment characteristics were not identified before deployment.
- C) MEASURE — bias metrics were not monitored in production.
- D) MANAGE — no incident response plan was activated when bias was discovered.

Answer: B **Explanation:** B is correct. The root failure was in MAP: the team did not contextualise that historical hiring data was biased, that the deployment context was high-stakes (employment decisions), or that the model's outputs would affect protected groups. Had MAP been applied, these risks would have been identified before deployment. C (no production monitoring) and D (slow response) were secondary failures. A (no policy) may also have been a factor but the exam-relevant answer focuses on the pre-deployment contextualisation failure.

Q6. A security analyst wants to quantify a deployed model's susceptibility to adversarial evasion attacks. Which AI RMF function and category is MOST relevant?

- A) GOVERN 2 — Accountability
- B) MAP 3 — Risk categorisation
- C) MEASURE 2 — AI risks are evaluated
- D) MANAGE 1 — Risks are prioritised

Answer: C **Explanation:** C is correct. Quantifying adversarial robustness — running standardised attacks and measuring attack success rates — is a MEASURE 2 activity. MAP 3 categorises risks as to likelihood and impact, but MAP does not conduct the measurement. GOVERN 2 is about accountability. MANAGE 1 prioritises risks after they have been measured.

Q7. Which of the following BEST describes the relationship between AI RMF Profiles and AI RMF Tiers?

- A) Profiles and Tiers are synonymous — both describe AI risk maturity.

- B) Profiles document current and target AI risk management state; Tiers describe the maturity and rigour of risk management practices.
- C) Tiers are mandatory compliance levels; Profiles are optional documentation tools.
- D) Profiles apply to specific AI systems; Tiers apply to specific AI functions (GOVERN, MAP, MEASURE, MANAGE).

Answer: B **Explanation:** B is correct. Profiles are used to document where an organisation is (Current Profile) and where it wants to be (Target Profile) in AI risk management. Tiers describe how sophisticated the overall AI risk management practice is — from informal (Tier 1) to adaptive (Tier 4). They are complementary, not synonymous. A is false. C is false — both Profiles and Tiers are voluntary tools, not compliance mandates. D is false — both Profiles and Tiers apply at the organisational level, not to individual functions or systems.

Q8. Which AI RMF function is responsible for ensuring that AI incidents are documented, investigated, and used to improve future risk management?

- A) GOVERN
- B) MAP
- C) MEASURE
- D) MANAGE

Answer: D **Explanation:** D is correct. MANAGE 4 explicitly requires that risk treatments incorporate knowledge from previous AI incidents — both internal and external. GOVERN sets the policy for incident response but does not conduct the investigation. MAP identifies risks prospectively, not retrospectively. MEASURE tracks performance metrics but does not drive the lessons-learned process.

Q9. Which statement about the NIST AI RMF's legal status is CORRECT?

- A) It is mandatory for all US organisations handling personal data.
- B) It is mandatory for US federal agencies under the AI Executive Order.
- C) It is voluntary guidance that organisations may adopt at their own discretion.
- D) It is legally binding for organisations operating in EU-regulated sectors.

Answer: C **Explanation:** C is correct. The AI RMF is voluntary guidance — it is not a regulation and creates no legal obligations for any organisation. B is partially misleading: the 2023 Executive Order required federal agencies to adopt AI risk management practices, but it did not make the AI RMF itself mandatory. A is false — no US law currently mandates the AI RMF. D is false — the AI RMF is not a legal instrument in any jurisdiction.

Q10. A data scientist argues that the MEASURE function only applies to model accuracy metrics. Which categories of MEASURE MOST directly refute this argument?

- A) MEASURE 1 and MEASURE 3 only.
- B) MEASURE 2.5 (fairness/bias) and MEASURE 2.6 (explainability).
- C) MEASURE 4 (residual risk) and MANAGE 1 (risk prioritisation).

D) MAP 2 (technical assumptions) and GOVERN 5 (risk culture).

Answer: B **Explanation:** B is correct. MEASURE 2.5 explicitly covers fairness and bias assessment; MEASURE 2.6 covers explainability assessment — both are independent of model accuracy. Together they demonstrate that MEASURE spans multiple dimensions of AI risk, not only predictive performance. A (MEASURE 1 and 3) are about method definition and monitoring, not the specific dimensions that refute the accuracy-only claim. C and D mix MANAGE and MAP functions with MEASURE.